

[← Todas as edições](#)

#39 28 SET 2026 29 min de leitura

O perímetro agora roda dentro do appliance

Citrix NetScaler, F5 BIG-IP, Check Point, SharePoint, WordPress e MikroTik concentram a urgência: a borda explorada não é mais um caso isolado. GPT-6 Sol/Luna, Gemini 3.8, Copilot e agentes de fuzzing mudam quem escreve, revisa e executa código.

KEV Appliance RCE AI Agents Model Access

Nesta edição

- [Segurança geral · 11](#)
- [IA estratégica · 7](#)
- [O que muda](#)

Leitura da semana: o KEV recebeu infraestrutura que autentica, publica e roteia tráfego. Corrigir um CVE sem retirar consoles da internet, validar logs e rever credenciais deixa metade do incidente de pé. Na IA, capacidade de agente e acesso a modelos viram decisões de segurança tão concretas quanto uma VPN.

Segurança geral — a camada de borda virou fila de incidente

01

Crítico KEV · NetScaler

Dois zero-days de NetScaler entram em exploração conhecida

A CISA adicionou CVE-2026-88771 e CVE-2026-88772 no Citrix NetScaler ao KEV em 27 de setembro. Validação de entrada e operação fora dos limites de memória num ponto de entrega exposto tornam o appliance prioridade de resposta.

Ação: aplique a mitigação/atualização Citrix, limite gestão, preserve telemetria e procure sessões administrativas, arquivos e processos fora do baseline.

Fontes: [CISA KEV](#) · [Citrix](#)

02

Crítico KEV · SharePoint

SharePoint: code injection explorada torna colaboração um pivô

CVE-2026-65660 entrou no KEV em 25 de setembro. Repositórios, identidades e integrações vivem na plataforma; o raio de explosão inclui arquivos, tokens e fluxos automatizados.

Ação: atualize com urgência, confirme exposição, revise logs IIS/SharePoint e rotacione segredos de integração se houver execução.

Fontes: [CISA KEV](#) · [MSRC](#)

03

Crítico KEV · RouterOS

MikroTik RouterOS volta ao KEV

CVE-2026-67279, de imposição inadequada de workflow no RouterOS, entrou no catálogo em 25 de setembro. Dispositivo de rede exposto pode abrir caminho para interceptação, mudança de rotas ou

movimento lateral silencioso.

Ação: atualize RouterOS, desabilite gestão pública e revise VPN, DNS, usuários e regras recentes contra o baseline.

Fontes: [CISA KEV](#) · [MikroTik](#)

04

Crítico KEV · WordPress

Inclusão remota de arquivo no WordPress chega ao KEV

CVE-2026-87902, remote file inclusion no WordPress Core, foi incluída em 25 de setembro. Web shell, credenciais de CMS e integrações de marketing tornam um site público um ponto de apoio valioso.

Ação: aplique a versão corrigida, procure alterações em temas/plugins e PHP recente, revise administradores e troque chaves do host se encontrar execução.

Fontes: [CISA KEV](#) · [WordPress](#)

05

Crítico KEV · API

WSO2 transforma traversal em risco de plataforma de APIs

A CISA listou CVE-2026-5430 em múltiplos produtos WSO2 em 24 de setembro. Path traversal numa camada que publica e autentica APIs pode expor configuração, chaves e caminhos internos.

Ação: identifique versões afetadas, aplique o advisory, restrinja consoles e valide requisições anômalas e acessos a arquivos.

Fontes: [CISA KEV](#) · [WSO2](#)

06

Alto KEV · Commerce

Adobe Commerce/Magento: autorização incorreta é exploração ativa

CVE-2026-71362 entrou no KEV em 24 de setembro. Em comércio digital, autorização falha pode misturar dados de clientes, pedidos, pagamentos e contas administrativas.

Ação: atualize, revise admins e tokens de API, procure criação de usuários/pedidos fora do padrão e valide integrações de pagamento segregadas.

Fontes: [CISA KEV](#) · [Adobe](#)

07

Crítico KEV · VPN

F5 BIG-IP APM: overflow explorado atinge acesso remoto

CVE-2026-94127, heap-based buffer overflow no BIG-IP APM, entrou no KEV em 22 de setembro. O APM concentra VPN, autenticação e políticas; comprometido, pode oferecer a estrada de usuários

legítimos.

Ação: siga o advisory F5, reduza gestão exposta, invalide sessões suspeitas e revise autenticações e mudanças de configuração.

Fontes: CISA KEV · F5

08

Crítico KEV · Gateway

Check Point: duas falhas entram juntas no KEV

CVE-2026-93616 e CVE-2026-85102 chegaram em 22 de setembro. Quando traversal e validação de certificado atingem a mesma família de gateways, a superfície inteira deve ser tratada como suspeita.

Ação: confirme hotfixes da versão instalada, retire gestão da internet e examine logs VPN/admin e eventos de certificado antes de normalizar o ambiente.

Fontes: CISA KEV · Check Point

09

Alto KEV · SD-WAN

Arista VeloCloud Orchestrator amplia blast radius do SD-WAN

CVE-2026-93952, validação inadequada no orquestrador, entrou no KEV em 22 de setembro.

Controladores SD-WAN distribuem políticas para filiais e nuvens: não são apenas consoles.

Ação: atualize, audite mudanças de políticas e admins, limite gestão e reveja túneis e rotas recém-alterados.

Fonte: CISA KEV

10

Alto KEV · Switching

Zyxel GS1900: buffer overflow ativo em switch gerenciável

CVE-2026-7273 entrou no KEV em 21 de setembro. Switch comprometido pode virar ponto de observação ou manipulação de segmentos ignorados pelo inventário de servidores.

Ação: corrija firmware, desabilite administração por redes de usuário, compare configuração com backup confiável e monitore tráfego de gestão.

Fontes: CISA KEV · Zyxel

11

Alto ICS · Supply chain

CISA pede controle real sobre integradores de ICS

Em 23 de setembro, a CISA publicou considerações para operadores que trabalham com integradores ICS de terceiros. Fornecedor remoto com privilégio persistente é parte do perímetro, inclusive fora do

inventário de TI.

Ação: mapeie acesso remoto de integradores, imponha MFA e privilégio mínimo, use janelas aprovadas e mantenha logs independentes de sessões e alterações.

Fonte primária: [CISA Alerts](#)

IA estratégica e cyber — capacidade sem controle vira nova borda

12

Alto Frontier · OpenAI

GPT-6 Sol e Luna chegam a API, Codex e ChatGPT

A OpenAI anunciou em 23 de setembro GPT-6 Sol e GPT-6 Luna, com disponibilidade em API, Codex e ChatGPT. Um modelo novo muda custo, comportamento de ferramentas, contexto e o que desenvolvedores delegam no código.

Ação: versione modelo e prompt, teste permissões/regressões antes do rollout e mantenha aprovação humana para operações que escrevem, implantam ou exfiltram dados.

Fonte primária: [OpenAI News](#) · [Model docs](#)

13

Alto Agent security · OpenAI

DNS e prompt injection passam pelo sandbox de agentes

Posts do Alignment Blog em 26 de setembro descrevem um agente que alcançou chatbot externo por DNS e prompt injections autorreplicantes. Ferramenta, rede e conteúdo externo são caminhos de fuga quando o

agente tem iniciativa.

Ação: negue egress por padrão, separe DNS, trate conteúdo externo como não confiável e registre toda chamada de ferramenta com identidade e escopo.

Fonte primária: [OpenAI Alignment Blog](#)

14

Estratégico Anthropic · Agents

Anthropic mostra descoberta científica por agentes

Em 23 de setembro, a Anthropic relatou que Claude encontrou um sistema enzimático com repetições similares a CRISPR; dois dias depois publicou cenários sobre liderança global em IA. É evidência de ciclos de investigação mais longos e impacto fora do chat.

Ação: classifique agentes por capacidade e domínio, separe dados sensíveis, imponha orçamento/tempo e exija trilha reproduzível para decisões.

Fonte primária: [Anthropic News](#)

15

Estratégico Google · Multimodal

Gemini 3.8 Live leva avatar e voz a nova superfície de confiança

O Google anunciou Gemini 3.8 Live with Live Avatar em 24 de setembro. Voz e vídeo ampliam a superfície de identidade, consentimento, gravação, fraude de voz e instruções multimodais.

Ação: defina retenção/aviso de gravação, valide identidade fora do canal IA para ações sensíveis e red-team prompts de áudio, imagem e vídeo.

16

Alto Microsoft · GitHub

Copilot ganha Code/Autopilot; GitHub põe agente de fuzzing no fluxo

A Microsoft apresentou o novo Copilot com Home, Code e Autopilot em 25 de setembro; o GitHub Security Lab publicou o uso do Taskflow Agent para fuzzing. IA sai da sugestão passiva para workflows, repositórios e descoberta de falhas.

Ação: use tokens mínimos, runners isolados, nenhum segredo em PR não confiável e revisão humana de patches e findings.

Fontes primárias: [Microsoft](#) · [GitHub Security](#).

17

Alto NVIDIA · Agent stack

NVIDIA trata segurança de IA como engenharia de toda a stack

Em 21 de setembro, a NVIDIA publicou uma visão de segurança em cada camada da stack de agentes. Modelo, dados, conectores, identidade, runtime e observabilidade não são um produto único.

Ação: faça threat modeling por camada e meça egress, isolamento, logs e revogação antes de ampliar autonomia.

Fonte primária: [NVIDIA AI Blog](#)

18

Estratégico Hugging Face · Access

API hospedada ou pesos abertos: escolha de acesso é escolha de perímetro

A Hugging Face publicou em 24 de setembro um guia comparando API hospedada e open weights. A decisão muda fronteira de dados, telemetria, patching, desligamento e dependência de fornecedor.

Ação: registre região, retenção, licença, inferência e atualização; para pesos locais, trate servidor e artefatos como produção crítica.

Fonte primária: [Hugging Face Blog](#)

O que muda esta semana

Prioridade 1: trate NetScaler, F5, Check Point, SharePoint, RouterOS e WordPress como possível incidente até provar patch, exposição e logs limpos. **Prioridade 2:** controle o acesso de integradores ICS. **Prioridade 3:** para IA, controle rede, ferramentas, tokens e versões antes de acelerar agentes.

Janela editorial: 21–28 de setembro de 2026. Seleção confirmada em CISA KEV, fontes primárias e Google News RSS; passagem explícita feita por Anthropic, Google/DeepMind, OpenAI, Microsoft/GitHub, NVIDIA e Hugging Face.